

Cours Réseau – Bases & Cybersécurité

SOMMAIRE :

Introduction.....	p.2
Chapitre 1 – Bases du réseau.....	p.3
Chapitre 2 – Modèles de référence réseau.....	p.4-5
Chapitre 3 – Adressage IP.....	p.6-8
Chapitre 4 – Protocoles fondamentaux.....	p.9-14
Chapitre 5 – Équipements réseau.....	p.15-20
Chapitre 6 – Fonctionnement des communications.....	p.21-26
Chapitre 7 – Réseau et sécurité.....	p.27-32
Chapitre 8 – Réseau et attaques.....	p.33-38
Chapitre 9 – Outils réseau.....	p.39-44
Chapitre 10 – Réseau en environnement réel.....	p.45-50
Conclusion.....	p.51

Introduction

Un réseau informatique est un ensemble de machines (ordinateurs, serveurs, téléphones, objets connectés) reliées entre elles afin de **communiquer et d'échanger des données**. Il constitue la base de presque tous les systèmes informatiques modernes, que ce soit dans les entreprises, les services publics ou les environnements domestiques.

En cybersécurité, le réseau joue un rôle central, car **c'est le canal principal par lequel transitent les informations sensibles** et le point d'entrée de la majorité des attaques. La sécurité réseau est donc essentielle pour protéger les données et assurer la continuité des services.

Exemples concrets :

- **Entreprise** : les employés accèdent aux serveurs, emails et applications via le réseau interne.
- **Attaque** : un pirate peut intercepter le trafic réseau pour voler des mots de passe ou injecter des logiciels malveillants.
- **Défense** : un pare-feu filtre les connexions pour bloquer les accès non autorisés et limiter la propagation des menaces.

Chapitre 1 – Bases du réseau

1. Types de réseaux

- **LAN (Local Area Network)** : réseau local, par exemple le réseau d'une maison ou d'une entreprise.
- **WAN (Wide Area Network)** : réseau étendu, reliant plusieurs LAN sur de longues distances (ex : Internet).

2. Supports de communication

- **Cuivre (Ethernet)** : câbles réseau classiques, fiables et très utilisés en entreprise.
- **Fibre optique** : très haut débit, utilisée pour les longues distances et Internet.
- **WiFi** : communication sans fil, pratique mais plus exposée aux attaques.

3. Notions clés

- **Bande passante** : capacité maximale de données qu'un réseau peut transporter.
- **Débit** : quantité réelle de données transmises par seconde.
- **Latence** : temps nécessaire pour qu'une donnée aille d'un point A à un point B.

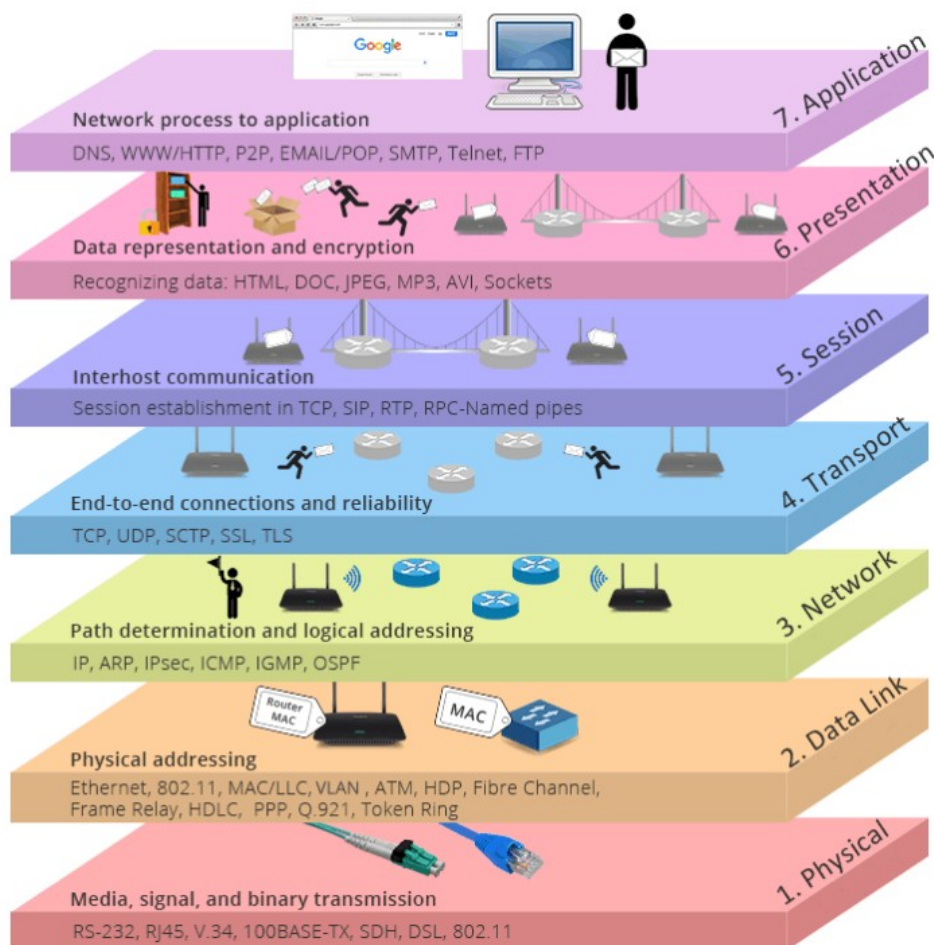
Ces notions sont essentiels pour comprendre le fonctionnement d'un réseau et analyser les performances ou les attaques en cybersécurité.

Chapitre 2 – Modèles de référence réseau

1. Modèle OSI

Le modèle OSI (Open Systems Interconnection) est un modèle théorique composé de **7 couches**. Il permet de comprendre comment les données circulent sur un réseau.

- **Couche 7 – Application** : interaction avec l'utilisateur (HTTP, FTP, SMTP).
- **Couche 6 – Présentation** : formatage, chiffrement, compression.
- **Couche 5 – Session** : gestion des sessions de communication.
- **Couche 4 – Transport** : fiabilité et ports (TCP, UDP).
- **Couche 3 – Réseau** : adressage et routage (IP).
- **Couche 2 – Liaison de données** : trames, MAC, commutation.
- **Couche 1 – Physique** : câbles, signaux, ondes.



2. Modèle TCP/IP

Le modèle TCP/IP est le modèle réellement utilisé sur Internet. Il est plus simple que le modèle OSI et **comporte 4 couches**.

- **Application** : services réseau (HTTP, FTP, DNS, SMTP).
- **Transport** : communication entre machines (TCP, UDP).
- **Internet** : adressage et routage (IP).
- **Accès réseau** : matériel et transmission physique.

3. Correspondance OSI / TCP-IP

Les couches du modèle OSI peuvent être regroupées pour correspondre aux couches du modèle TCP/IP.

- OSI 7, 6, 5 → TCP/IP Application
- OSI 4 → TCP/IP Transport
- OSI 3 → TCP/IP Internet
- OSI 2, 1 → TCP/IP Accès réseau

4. Utilité des modèles en cybersécurité

Les modèles OSI et TCP/IP sont essentiels en cybersécurité pour analyser, comprendre et bloquer les attaques réseau.

- Identifier où se situe une attaque (réseau, transport ou applicatif).
 - Mettre en place des protections adaptées (pare-feu, IDS, WAF).
 - Diagnostiquer les problèmes réseau plus rapidement.
 - Faciliter la communication entre équipes IT et sécurité.
- Ces modèles servent de base pour comprendre le réseau et raisonner efficacement en cybersécurité.

Chapitre 3 – Adressage IP

1. IPv4 et IPv6

IPv4

- Adresse sur **32 bits** → 4 octets (ex : 192 . 168 . 1 . 1).
- Permet ~4,3 milliards d'adresses uniques.
- Limité face à la croissance d'Internet → utilisation du **NAT** pour partager une même adresse publique entre plusieurs machines.
- **Types d'adresses IPv4 :**
 - **Publiques** : routables sur Internet.
 - **Privées** : réservées pour réseaux locaux (10.0.0.0/8, 172.16.0.0/12, 192.168.0.0/16).
 - **Loopback** : 127.0.0.1 pour tests internes.
 - **APIPA** : 169.254.0.0/16, attribuée automatiquement si DHCP indisponible.

2. Structure d'une adresse IP

- **Partie réseau** : identifie le réseau auquel appartient la machine.
- **Partie hôte** : identifie la machine dans ce réseau.

Exemple IPv4

- **Adresse** : 192 . 168 . 10 . 25/24
- **Masque réseau** : 255 . 255 . 255 . 0
- **Plage d'hôtes** : 192.168.10.1 → 192.168.10.254
- **Adresse réseau** : 192.168.10.0
- **Adresse broadcast** : 192.168.10.255

Types d'adresses

- **Public** : visible sur Internet.
- **Privée** : RFC1918, utilisée localement.
- **Loopback** : 127.0.0.1, tests locaux.
- **APIPA** : automatique si pas de DHCP.

3. CIDR (Classless Inter-Domain Routing)

- Remplace l'ancien système de classes A, B, C.
- Notation /x : nombre de bits réseau.
- Permet une allocation **flexible** et optimisée des adresses.

Exemples :

- 10.0.0.0/8 → très grand réseau
- 192.168.1.0/24 → réseau local

Avantages :

- Réduction du gaspillage d'adresses
- Simplification du routage
- Meilleure hiérarchisation des réseaux

4. Subnetting

- Découper un réseau en **plusieurs sous-réseaux** pour sécurité et organisation.

Objectifs

- Sécurité → limitation propagation attaque.
- Organisation → séparer services ou départements.
- Performance → réduire broadcast et congestion.

Étapes pratiques

1. Identifier le nombre d'hôtes nécessaires.
2. Choisir un masque adapté.
3. Calculer :
 - Adresse réseau
 - Adresse broadcast
 - Plage d'adresses utilisables

Exemples :

- Réseau initial : 192.168.1.0/24
- Sous-réseaux : /26 pour diviser en 4 réseaux de 62 hôtes.

5. VLSM (Variable Length Subnet Mask)

- Permet des **sous-réseaux de tailles différentes** selon les besoins.
- Optimise l'espace IP.

Exemples :

- RH : /26 → 62 hôtes
- IT : /24 → 254 hôtes
- Invités : /27 → 30 hôtes

Avantage : adaptation fine à la structure réelle de l'entreprise.

Partie réseau			Partie hôte
IPv4 : 192.168.178.31			
8 bits	8 bits	8 bits	8 bits

Préfixe				Identificateur d'interface			
IPv6 : 0000:0000:0000:0000:0000:ffff:c0a8:b21f							
16 bits	16 bits	16 bits	16 bits	16 bits	16 bits	16 bits	16 bits

Chapitre 4 – Protocoles fondamentaux

1. TCP et UDP

TCP (Transmission Control Protocol)

Type : Orienté connexion

Objectif : Fiabilité et intégrité des données

Fonctionnement

TCP établit une connexion avant l'échange de données via le **three-way handshake** :

1. SYN → Le client envoie une demande de connexion au serveur.
→ Il dit : *“Je veux me connecter.”*
2. SYN-ACK → Le serveur répond qu'il accepte la connexion.
→ Il dit : *“D'accord, j'ai reçu ta demande et je suis prêt.”*
3. ACK → Le client confirme qu'il a bien reçu la réponse du serveur.
→ Il dit : *“Parfait, la connexion est établie.”*

Ensuite :

- Numérotation des segments
- Accusés de réception (ACK)
- Retransmission des paquets perdus
- Contrôle de flux (évite de saturer le récepteur)
- Contrôle de congestion (évite la surcharge réseau)

Avantages

- Fiable
- Ordre garanti
- Détection d'erreurs

Inconvénients

- Plus lent (overhead important)

Exemples d'utilisation :

- HTTP (navigation web)
- HTTPS
- FTP
- SMTP

UDP (User Datagram Protocol)

Type : Non orienté connexion

Objectif : Rapidité

Fonctionnement

- Pas d'établissement de connexion
- Pas d'accusé de réception
- Pas de retransmission
- Envoi direct des datagrammes

Avantages

- Très rapide
- Faible latence
- Faible surcharge

Inconvénients

- Aucune garantie de livraison
- Ordre non garanti

Exemples d'utilisation

- DNS (requêtes rapides)
- Streaming vidéo
- VoIP (Voice over IP)
- Jeux en ligne

2. ICMP (Internet Control Message Protocol)

Rôle : Diagnostic et gestion des erreurs

ICMP ne transporte pas de données applicatives. Il informe sur :

- Destination inaccessible
- Temps dépassé (TTL expired)
- Problème de fragmentation

Exemple pratique

La commande **ping** envoie des requêtes ICMP Echo Request et attend un Echo Reply.

Autre outil :

- traceroute (utilise ICMP Time Exceeded)

ICMP peut être utilisé pour :

- Cartographier un réseau
- Attaques par flood ICMP (DoS)

3. ARP (Address Resolution Protocol)

Rôle : Associer une adresse IP à une adresse MAC dans un réseau local (LAN).

Pourquoi ?

Les communications Ethernet utilisent les adresses MAC, mais les applications utilisent les IP.

ARP fait la correspondance.

Fonctionnement

1. ARP Request (broadcast) : "Qui a l'IP 192.168.1.10 ?"
2. ARP Reply : "C'est moi, voici ma MAC"

Les réponses sont stockées dans la **table ARP**.

Vulnérabilité

ARP Spoofing :

- Un attaquant envoie de fausses réponses ARP
- Peut permettre :
 - Man-in-the-Middle
 - Interception de trafic

4. DNS (Domain Name System)

Rôle : Traduire un nom de domaine en adresse IP.

Exemple :

google.com → 142.250.x.x

Structure hiérarchique

1. Serveurs racine
2. TLD (.com, .fr, .org...)
3. Serveur autoritatif

Ports

- UDP 53 (principalement)
- TCP 53 (transferts de zone ou réponses volumineuses)

Types d'enregistrements

- A → IPv4
- AAAA → IPv6
- MX → Mail
- CNAME → Alias
- NS → Serveur de noms

Attaques courantes

- DNS spoofing
- Cache poisoning
- Amplification DNS (DdoS)

5. DHCP (Dynamic Host Configuration Protocol)

Rôle : Attribution automatique de configuration réseau.

Attribue :

- Adresse IP
- Masque
- Passerelle par défaut
- Serveur DNS

Processus DORA

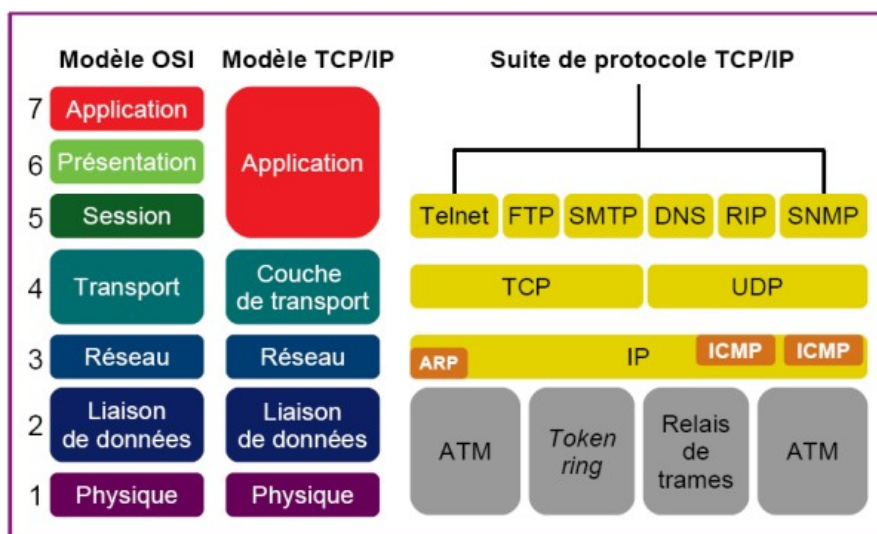
1. Discover (broadcast client)
2. Offer (serveur propose une IP)
3. Request (client accepte)
4. Acknowledge (confirmation finale)

Ports

- UDP 67 (serveur)
- UDP 68 (client)

Risques

- Rogue DHCP server
- Attribution d'IP malveillante



6. HTTP et HTTPS

HTTP (HyperText Transfer Protocol)

Port : 80

Caractéristiques :

- Non chiffré
- Basé sur requête/réponse
- Méthodes : GET, POST, PUT, DELETE

Problème : données en clair (interception possible)

HTTPS (HTTP Secure)

Port : 443

Basé sur :

- TLS (anciennement SSL)

Apporte :

- Confidentialité (chiffrement)
- Intégrité
- Authentification via certificat numérique

Exemple concret

- Banque en ligne
- Email
- E-commerce

Le navigateur vérifie :

- Certificat valide
- Autorité de certification (CA)
- Correspondance du domaine

Chapitre 5 – Équipements réseau

1. Switch (Commutateur)

Couche OSI : Couche 2 (Liaison de données)

Rôle : Connecter plusieurs équipements dans un réseau local (LAN)

Fonctionnement

- Analyse les **adresses MAC**
- Maintient une **table MAC (CAM table)**
- Envoie les trames uniquement vers le port concerné (contrairement au hub)

Types de switch

- **Non manageable** : configuration simple
- **Manageable** : configuration avancée (VLAN, QoS, sécurité)
- **Layer 3 switch** : peut aussi faire du routage

VLAN (Virtual LAN)

Permet de segmenter logiquement un réseau :

Exemple :

- VLAN 10 → Administration
- VLAN 20 → Comptabilité
- VLAN 30 → Invités

Avantages :

- Sécurité accrue
- Réduction du broadcast
- Meilleure organisation réseau

Sécurité

- Port security (limiter les MAC autorisées)
- Désactivation ports inutilisés
- Protection contre VLAN hoppingt

2. Routeur

Couche OSI : Couche 3 (Réseau)

Rôle : Interconnecter plusieurs réseaux

Fonctionnement

- Analyse les **adresses IP**
- Utilise une **table de routage**
- Choisit le meilleur chemin (meilleure métrique)

Types de routage

- **Statique** : configuré manuellement
- **Dynamique** : via protocoles comme :
 - RIP
 - OSPF
 - BGP

Fonctions supplémentaires

- NAT (traduction IP privée ↔ publique)
- DHCP
- Filtrage de base
- QoS

Exemple :

Internet ↔ Routeur ↔ Réseau interne

Le routeur est la **passerelle par défaut**.

3. Pare-feu

Rôle : Protéger le réseau en contrôlant le trafic entrant et sortant.

Types de filtrage

1. **Filtrage statique (packet filtering)**
Basé sur IP, port, protocole
2. **Stateful inspection**
Analyse l'état des connexions (plus sécurisé)
3. **Next-Generation Firewall (NGFW)**
Inspection profonde des paquets (DPI)
Détection applications
Intégration IDS/IPS

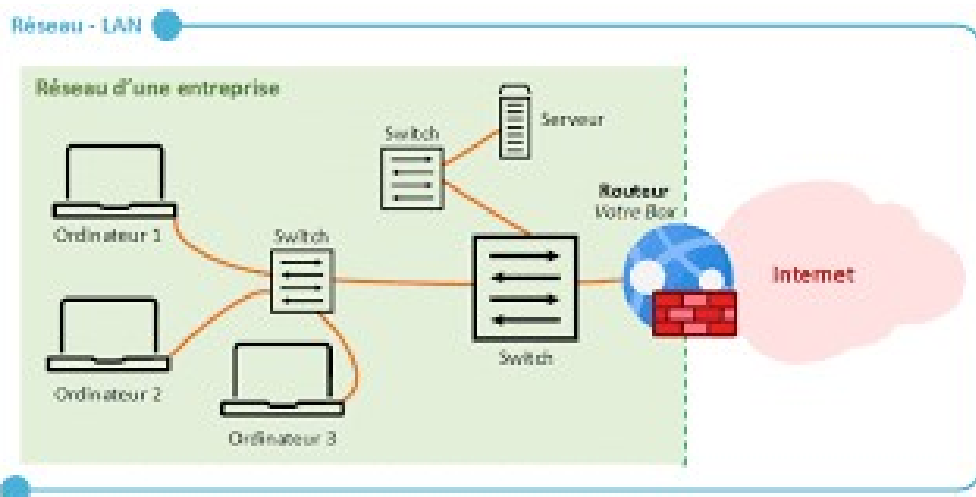
Politique de sécurité

Basée sur règles :

- Autoriser
- Refuser
- Journaliser

Zones courantes

- LAN
- WAN
- DMZ (zone démilitarisée)



4. IDS / IPS

IDS (Intrusion Detection System)

- Surveille le trafic
- Détecte les comportements suspects
- Alerte seulement

IPS (Intrusion Prevention System)

- Détecte ET bloque automatiquement
- Placé en ligne dans le réseau

Méthodes de détection

- Par signatures (attaques connues)
- Par anomalies (comportement inhabituel)
- Analyse heuristique

Exemple d'attaques détectées

- Scan de ports
- Tentatives de brute force
- Exploits connus

5. Proxy

Rôle : Intermédiaire entre client et serveur.

Types

- **Proxy forward** (utilisateurs → Internet)
- **Proxy reverse** (protège serveurs internes)

Fonctions

- Filtrage web
- Contrôle d'accès
- Cache (améliore performances)
- Masquage IP interne
- Journalisation

Avantages

- Sécurité
- Optimisation bande passante
- Contrôle centralisé

6. Point d'accès Wi-Fi (Access Point – AP)

Rôle : Connecter un réseau filaire à un réseau sans fil.

Fonctionnement

- Diffuse un **SSID**
- Permet aux appareils Wi-Fi de se connecter
- Relié au switch via câble Ethernet

Modes

- Mode AP (classique)
- Mode bridge
- Mode répéteur

Sécurité Wi-Fi

WPA2

- Chiffrement AES
- Authentification par mot de passe ou 802.1X
- Vulnérable à certaines attaques (KRACK)

WPA3 (plus sécurisé)

- Protection contre brute force
- Chiffrement individualisé
- Sécurité renforcée sur réseaux publics

Bonnes pratiques :

- Désactiver WPS
- Changer SSID par défaut
- Mot de passe fort
- Séparer Wi-Fi invité
- Activer WPA3 si possible

Chapitre 6 – Fonctionnement des communications

1. Encapsulation : du message aux bits

L'encapsulation est le processus par lequel les données sont progressivement encapsulées à chaque couche du modèle réseau (référence au Modèle OSI et au modèle TCP/IP).

Étapes de transformation :

1. **Données (couche Application)**

Exemple : requête HTTP, email SMTP, transfert FTP.

2. **Segment (couche Transport – TCP/UDP)**

Ajout d'un en-tête contenant :

- Port source
- Port destination
- Numéro de séquence (TCP)
- Numéro d'accusé de réception
- Checksum
- Fenêtre de contrôle

TCP assure la fiabilité. UDP privilégie la rapidité.

3. **Paquet (couche Réseau – IP)**

Ajout d'un en-tête IP contenant :

- Adresse IP source
- Adresse IP destination
- TTL (Time To Live)
- Protocole encapsulé (TCP/UDP)
- Identification (fragmentation)

4. **Trame (couche Liaison – Ethernet/Wi-Fi)**

Ajout :

- Adresse MAC source
- Adresse MAC destination

- Type
- FCS (Frame Check Sequence)

5. Bits (couche Physique)

Transmission sous forme de signaux électriques, optiques ou radio.

Désencapsulation

À la réception, chaque couche retire son en-tête jusqu'à remise des données à l'application.

2. Handshake TCP : établissement d'une connexion fiable

TCP (Transmission Control Protocol) établit une connexion orientée et fiable.

Établissement de connexion : 3-Way Handshake

1. SYN
Le client envoie un segment SYN avec un numéro de séquence initial.
2. SYN-ACK
Le serveur répond avec SYN + ACK.
3. ACK
Le client confirme.

La connexion est alors établie et les numéros de séquence sont synchronisés.

Fermeture de connexion

1. FIN
2. ACK
3. FIN
4. ACK

Mécanismes de fiabilité TCP

- Accusés de réception (ACK)
- Retransmission en cas de perte
- Contrôle de flux (Window Size)
- Contrôle de congestion :
 - Slow Start
 - Congestion Avoidance
 - Fast Retransmit
 - Fast Recovery

3. Résolution DNS : traduction nom ↔ adresse IP

Le DNS (Domain Name System) traduit un nom de domaine en adresse IP.

Étapes de résolution

1. Vérification cache local (navigateur / système)
2. Envoi au résolveur DNS
3. Requête vers un serveur racine
4. Redirection vers serveur TLD (.com, .fr...)
5. Interrogation du serveur autoritatif
6. Retour de l'adresse IP au client

Hiérarchie DNS

- Racine (.)
- Domaine de premier niveau (TLD)
- Domaine
- Sous-domaine

Types d'enregistrements

- A : IPv4
- AAAA : IPv6
- CNAME : alias
- MX : messagerie
- NS : serveur DNS
- TXT : informations diverses

Sécurité

- DNSSEC : validation cryptographique
- Risques : spoofing, cache poisoning

4. Routage : détermination du chemin

Le routage permet aux paquets IP de circuler entre réseaux.

Routage statique

- Configuré manuellement
- Adapté aux petits réseaux
- Pas d'adaptation automatique

Routage dynamique

Protocoles d'échange automatique :

- OSPF
 - IGP (Interior Gateway Protocol)
 - Basé sur le coût
 - Convergence rapide
- BGP
 - EGP (Exterior Gateway Protocol)
 - Utilisé sur Internet
 - Basé sur les systèmes autonomes (AS)

Table de routage

Contient :

- Réseau destination
- Masque
- Passerelle (next hop)
- Interface de sortie
- Métrique

Processus de décision

1. Correspondance la plus spécifique (Longest Prefix Match)
2. Sélection selon métrique
3. Transmission vers la passerelle

5. NAT : traduction d'adresses

Le NAT (Network Address Translation) permet la communication entre réseaux privés et Internet.

Objectifs

- Économie d'adresses IPv4
- Masquage du réseau interne
- Séparation logique

Types de NAT

1. SNAT (Source NAT)
Modification de l'adresse source sortante.
2. DNAT (Destination NAT)
Modification de l'adresse destination entrante.
3. PAT (Port Address Translation)
Traduction avec différenciation par numéro de port.
Permet à plusieurs machines de partager une même IP publique.

Fonctionnement

Le routeur maintient une table de correspondance :

IP privée → Port privé → IP publique → Port public

Limites

- Complexité pour VoIP et P2P
- Nécessite parfois des mécanismes complémentaires (UPnP, STUN)
- Devient inutile en IPv6 (adressage massif)

6. Éléments complémentaires essentiels

ARP

Protocole de résolution IP → MAC en réseau local.

ICMP

Protocole de messages d'erreur et de diagnostic (exemple : ping).

MTU

Taille maximale d'un paquet sans fragmentation (Ethernet standard : 1500 octets).

Fragmentation IP

Découpage d'un paquet si sa taille dépasse la MTU.

Synthèse du fonctionnement global

1. L'application génère les données
2. Encapsulation via TCP/UDP, puis IP, puis trame
3. Résolution DNS si nécessaire
4. Routage via tables et protocoles
5. Traduction NAT si sortie vers Internet
6. Transmission physique
7. Désencapsulation côté réception

Chapitre 7 – Réseau et sécurité

1. Segmentation réseau : VLAN et isolation

La segmentation consiste à diviser un réseau en plusieurs segments logiques afin d'améliorer la sécurité, les performances et la gestion.

VLAN (Virtual Local Area Network)

Un VLAN permet de créer plusieurs réseaux logiques sur une même infrastructure physique (switches).

Norme associée : IEEE 802.1Q

Objectifs

- Isolation logique des services (RH, finance, production)
- Réduction du domaine de broadcast
- Limitation de la propagation d'une attaque (ex : ransomware)
- Application de politiques de sécurité spécifiques par segment

Fonctionnement

- Les trames Ethernet sont taguées avec un identifiant VLAN (VLAN ID).
- Les ports de switch peuvent être :
 - Access (un seul VLAN)
 - Trunk (plusieurs VLAN tagués)

Inter-VLAN Routing

La communication entre VLAN nécessite :

- Un routeur
- Ou un switch de niveau 3

Cela permet d'appliquer des règles de filtrage entre segments.

2. DMZ : zone démilitarisée

Une DMZ (Demilitarized Zone) est une zone réseau intermédiaire entre Internet et le réseau interne.

Objectif

- Héberger les services exposés au public
- Protéger le réseau interne en cas de compromission

Services typiquement placés en DMZ

- Serveur web
- Serveur mail
- Serveur DNS public
- Reverse proxy

Architecture classique

Internet

↓

Pare-feu externe

↓

DMZ

↓

Pare-feu interne

↓

Réseau interne

Principe de sécurité

Même si un serveur en DMZ est compromis, l'attaquant ne peut pas accéder directement au réseau interne grâce aux règles strictes du pare-feu interne.

3. Filtrage réseau : contrôle du trafic

Le filtrage réseau permet de contrôler quels flux sont autorisés ou bloqués.

ACL (Access Control List)

Une ACL est une liste de règles définissant :

- Adresse IP source
- Adresse IP destination
- Port
- Protocole
- Action (permit / deny)

Les ACL peuvent être :

- Standard (filtrage IP source)
- Étendues (filtrage complet IP, ports, protocoles)

Pare-feu (Firewall)

Types de filtrage :

1. Filtrage stateless
Analyse paquet par paquet.
2. Filtrage stateful
Analyse en tenant compte de l'état de la connexion.
3. Inspection approfondie (DPI – Deep Packet Inspection)
Analyse du contenu applicatif.

Les pare-feu modernes peuvent intégrer :

- IDS (Intrusion Detection System)
- IPS (Intrusion Prevention System)
- Filtrage applicatif

4. VPN : réseau privé virtuel

Un VPN permet d'établir un tunnel chiffré entre deux points via un réseau public.

Objectifs

- Confidentialité
- Intégrité
- Authentification
- Accès distant sécurisé

Fonctionnement général

1. Authentification du client
2. Négociation des clés
3. Création du tunnel chiffré
4. Transmission encapsulée

Protocoles VPN

- IPsec
 - Fonctionne au niveau réseau
 - Modes transport et tunnel
 - Très utilisé en site-à-site
- OpenVPN
 - Basé sur SSL/TLS
 - Flexible
 - Utilisé pour accès distant
- WireGuard
 - Moderne
 - Léger
 - Performant
 - Configuration simplifiée

Types de VPN

- Site-à-site (entre deux réseaux)
- Client-à-site (télétravail)
- VPN full tunnel / split tunnel

5. Zero Trust : modèle de sécurité moderne

Le modèle Zero Trust repose sur un principe fondamental :

Aucune confiance implicite, même à l'intérieur du réseau.

Concept popularisé par Forrester Research.

Principes clés

1. Vérification continue
Chaque accès doit être authentifié et autorisé.
2. Principe du moindre privilège
Accès limité au strict nécessaire.
3. Micro-segmentation
Segmentation fine des ressources.
4. Surveillance permanente
Analyse comportementale et journalisation.

Composants typiques

- Authentification multi-facteurs (MFA)
- Gestion des identités (IAM)
- Contrôle d'accès basé sur le contexte
- Analyse en temps réel

Différence avec modèle traditionnel :

Modèle classique :

Une fois dans le réseau interne → confiance élevée.

Modèle Zero Trust :

Chaque requête est vérifiée indépendamment.

6. Compléments essentiels en sécurité réseau

IDS / IPS

- IDS : détection d'intrusion (alerte)
- IPS : prévention (blocage automatique)

Proxy et reverse proxy

- Proxy : contrôle trafic sortant
- Reverse proxy : protège serveurs internes

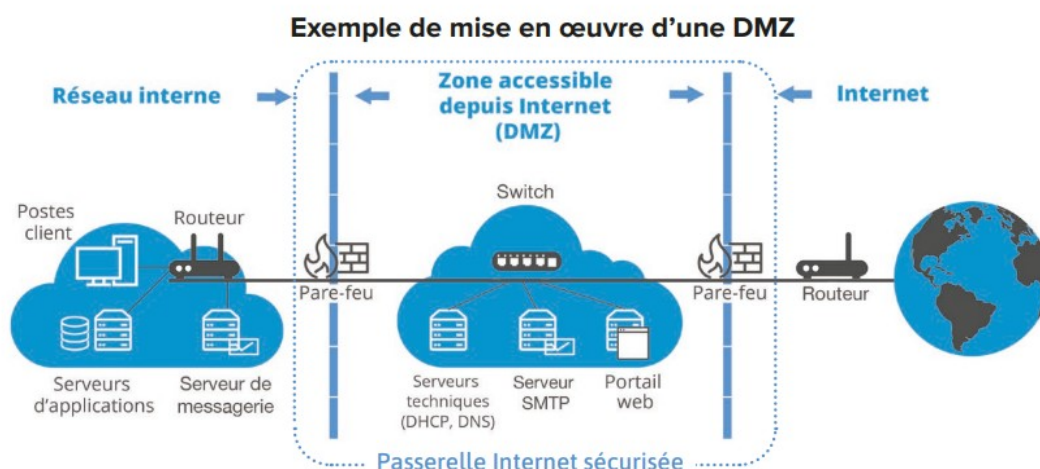
Journalisation (logs)

Indispensable pour :

- Audit
- Analyse post-incident
- Conformité réglementaire

Synthèse globale :

1. Segmentation (VLAN) pour limiter la surface d'attaque
2. DMZ pour isoler les services exposés
3. Filtrage via ACL et pare-feu
4. VPN pour sécuriser les communications distantes
5. Zero Trust pour supprimer toute confiance implicite



Chapitre 8 – Réseau et attaques

Les attaques réseau exploitent les vulnérabilités des protocoles, des équipements ou des configurations afin de compromettre la confidentialité, l'intégrité ou la disponibilité des systèmes d'information.

1. Sniffing (écoute du trafic réseau)

Le sniffing consiste à intercepter et analyser les paquets circulant sur un réseau.

Fonctionnement

Un attaquant utilise un outil de capture de paquets (comme Wireshark ou tcpdump) pour observer le trafic réseau.

Sur un réseau local, cela peut impliquer :

- L'activation du mode promiscuous de la carte réseau
- Une attaque préalable permettant de rediriger le trafic (ex : ARP Spoofing)

Dans un réseau commuté (switch), le trafic n'est normalement pas visible par tous les hôtes, ce qui oblige l'attaquant à détourner les flux.

Objectifs

- Récupération d'identifiants et mots de passe
- Vol de cookies de session
- Collecte d'informations sensibles
- Analyse du fonctionnement du réseau

Risques

Les protocoles non chiffrés (HTTP, FTP, Telnet) transmettent les données en clair. Toute personne interceptant le trafic peut lire les informations.

Contre-mesures

- Utilisation de protocoles chiffrés (HTTPS, TLS, SSH)
- VPN pour les connexions distantes
- Segmentation du réseau
- Surveillance du trafic anormal

2. MITM (Man In The Middle)

L'attaque Man In The Middle consiste à s'interposer entre deux entités qui communiquent afin d'intercepter ou modifier les échanges sans que celles-ci ne s'en rendent compte.

Fonctionnement

L'attaquant se place entre la victime et le serveur.

Victime ↔ Attaquant ↔ Serveur

Il peut :

- Lire les données échangées
- Modifier les messages
- Injecter du contenu malveillant
- Détourner des transactions

Exemples

- Faux point d'accès Wi-Fi
- Interception HTTPS avec certificat frauduleux
- ARP Spoofing sur réseau local

Conséquences

- Vol d'identifiants
- Manipulation de transactions bancaires
- Infection par malware

Contre-mesures

- Vérification des certificats SSL/TLS
- Utilisation de HSTS
- Authentification forte
- Surveillance des anomalies réseau

3. ARP Spoofing

L'ARP Spoofing est une attaque ciblant les réseaux locaux (LAN). Elle exploite le protocole ARP (Address Resolution Protocol), utilisé pour associer une adresse IP à une adresse MAC.

Fonctionnement

L'attaquant envoie de fausses réponses ARP pour faire croire que son adresse MAC correspond à l'adresse IP d'un autre équipement (ex : passerelle).

Ainsi, le trafic destiné à la passerelle est redirigé vers l'attaquant.

Objectifs

- Interception du trafic (MITM)
- Modification des données
- Dénis de service

Vulnérabilité

Le protocole ARP ne dispose d'aucun mécanisme d'authentification.

Contre-mesures

- ARP statique
- Dynamic ARP Inspection (DAI)
- Segmentation réseau
- Surveillance des tables ARP

4. DNS Spoofing

Le DNS Spoofing consiste à falsifier la résolution DNS afin de rediriger une victime vers un site malveillant.

Fonctionnement

L'attaquant modifie la réponse DNS pour associer un nom de domaine légitime à une adresse IP frauduleuse.

Exemple :

www.banque.com → IP du serveur malveillant au lieu du serveur officiel.

Objectifs

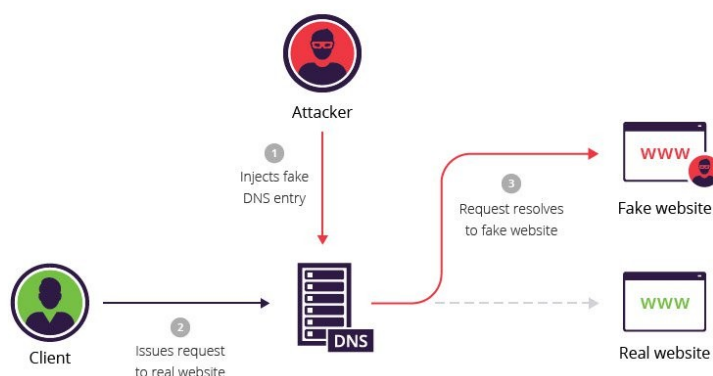
- Phishing
- Vol d'identifiants
- Installation de malware

Techniques utilisées

- Empoisonnement du cache DNS
- Compromission d'un serveur DNS
- Attaque MITM

Contre-mesures

- DNSSEC
- HTTPS avec vérification du certificat
- Surveillance des serveurs DNS



5. DDoS (Distributed Denial of Service)

Le DDoS vise à rendre un service indisponible en saturant ses ressources.

Principe

Un grand nombre de machines compromises (botnet) envoient simultanément des requêtes vers une cible.

Types d'attaques

- Volumétriques : saturation de la bande passante
- Attaques protocolaires : exploitation des faiblesses TCP/IP
- Attaques applicatives : surcharge d'un service web

Techniques d'amplification

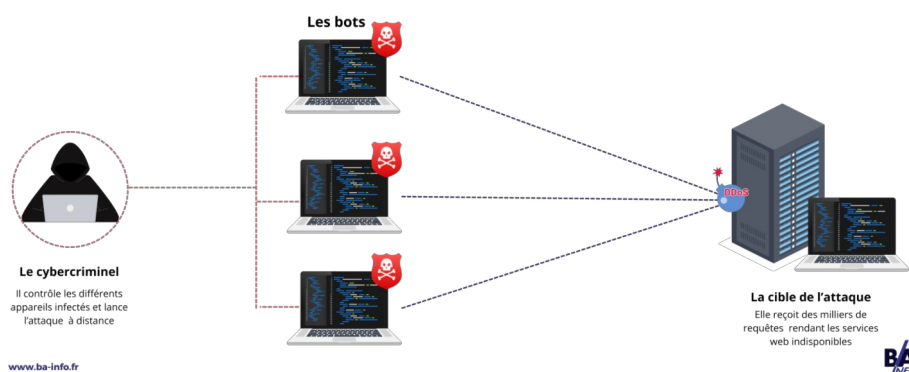
Certaines attaques exploitent des serveurs tiers (DNS, NTP) pour amplifier le trafic.

Conséquences

- Indisponibilité du site ou service
- Perte financière
- Atteinte à la réputation

Contre-mesures

- Pare-feu et systèmes anti-DDoS
- Répartition de charge (load balancing)
- CDN
- Filtrage du trafic



6. Scan réseau

Le scan réseau est une phase de reconnaissance permettant d'identifier les hôtes, ports ouverts et services actifs.

Objectifs

- Découvrir les machines présentes
- Identifier les systèmes d'exploitation
- Détecter les services vulnérables

Types de scans

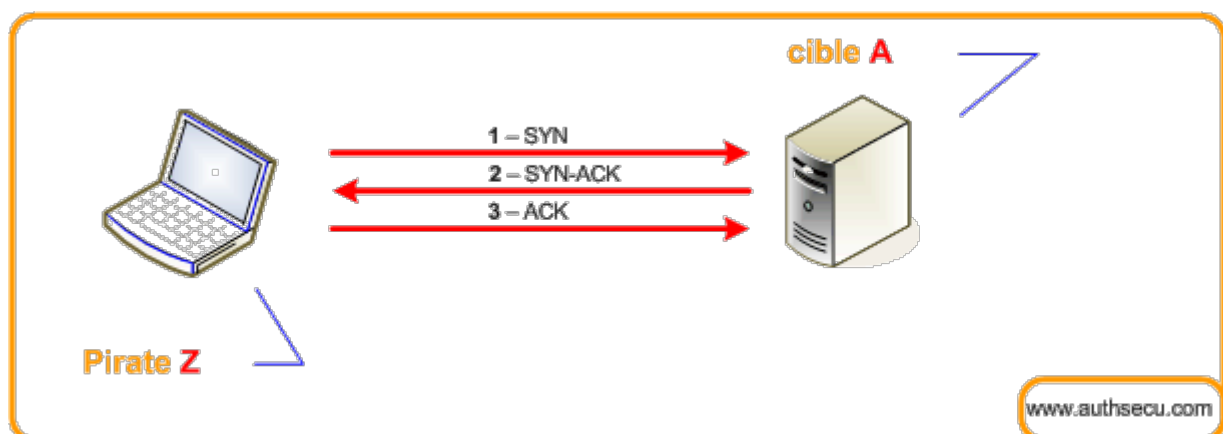
- Scan de ports (TCP, UDP)
- Scan SYN
- Scan de version de service
- Scan de vulnérabilités

Utilisation

Le scan peut être utilisé de manière légitime (audit de sécurité) ou malveillante (préparation d'attaque).

Contre-mesures

- Pare-feu
- IDS/IPS
- Désactivation des services inutiles
- Surveillance des logs



Chapitre 9 – Outils réseau

Les outils réseau permettent d'analyser, diagnostiquer, sécuriser et surveiller les infrastructures informatiques. Ils sont utilisés aussi bien par les administrateurs systèmes que par les experts en cybersécurité.

1. Ping

Ping est un outil de base permettant de tester la connectivité entre deux machines sur un réseau.

Principe de fonctionnement

Ping utilise le protocole ICMP (Internet Control Message Protocol).

Il envoie une requête ICMP Echo Request à une machine distante qui répond par une Echo Reply.

Informations obtenues

- Disponibilité d'un hôte
- Temps aller-retour (latence)
- Perte de paquets
- Stabilité de la connexion

Utilisation

- Vérifier si un serveur est accessible
- Tester la connectivité réseau locale ou distante
- Diagnostiquer un problème de réseau

Limites

- Certains pare-feu bloquent les requêtes ICMP
- Ne permet pas d'identifier la cause précise d'une panne

2. Traceroute

Traceroute permet d'analyser le chemin emprunté par les paquets entre la source et la destination.

Principe de fonctionnement

Il envoie des paquets avec un TTL (Time To Live) progressivement augmenté.

Chaque routeur traversé décrémente le TTL.

Lorsque le TTL atteint zéro, le routeur renvoie un message ICMP indiquant sa présence.

Ainsi, on obtient la liste des routeurs intermédiaires.

Informations obtenues

- Chemin réseau complet
- Temps de réponse à chaque saut
- Localisation approximative des équipements

Utilisation

- Identifier un point de blocage
- Détecter un ralentissement sur un segment précis
- Diagnostiquer un problème de routage

Limites

- Certains routeurs bloquent les réponses ICMP
- Le chemin peut varier selon la charge réseau

3. Netstat / ss

Netstat et ss sont des outils permettant d'afficher les connexions réseau actives et les ports ouverts.

Fonctionnalités principales

- Liste des connexions TCP et UDP
- Identification des ports en écoute
- Affichage des processus associés
- Statistiques réseau

Différences

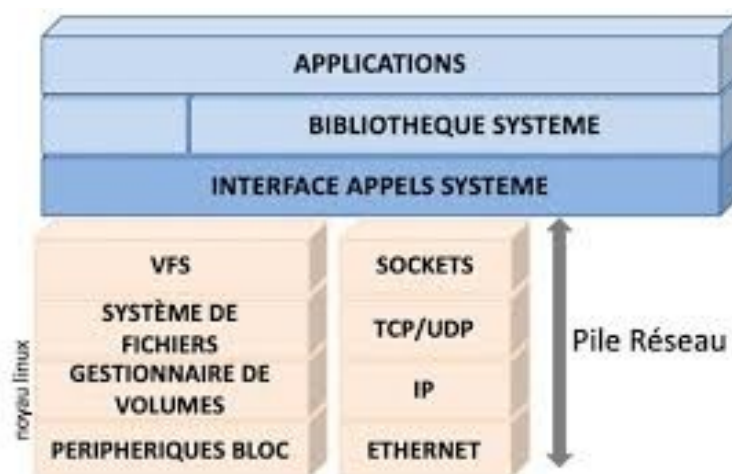
- Netstat est ancien mais encore utilisé
- ss est plus rapide et plus performant sur les systèmes Linux modernes

Utilisation

- Vérifier quels services sont exposés
- Identifier une connexion suspecte
- Analyser les sessions actives

Importance en cybersécurité

Ces outils permettent de détecter une compromission ou un service mal configuré.



4. Nmap

Nmap est un outil avancé de scan réseau et de cartographie.

Fonctionnalités principales

- Scan de ports TCP et UDP
- Détection de services et versions
- Identification du système d'exploitation
- Scripts de détection de vulnérabilités

Types de scans

- Scan SYN (discret)
- Scan complet TCP
- Scan UDP
- Scan de version
- Scan OS

Utilisation

- Audit de sécurité
- Cartographie d'un réseau
- Détection de services non autorisés

Importance

Nmap est un outil central en phase de reconnaissance lors d'un test d'intrusion.

5. Wireshark

Wireshark est un analyseur de paquets graphique utilisé pour examiner en détail le trafic réseau.

Fonctionnalités

- Capture en temps réel
- Analyse approfondie des protocoles
- Filtrage avancé des paquets
- Reconstruction de flux

Utilisation

- Diagnostic réseau
- Analyse d'attaque
- Investigation forensic
- Étude du fonctionnement des protocoles

Avantages

- Interface graphique détaillée
- Décodage automatique de nombreux protocoles

Limites

- Consomme des ressources
- Nécessite des connaissances en protocoles réseau

6. Tcpdump

Tcpdump est un outil de capture de paquets en ligne de commande.

Caractéristiques

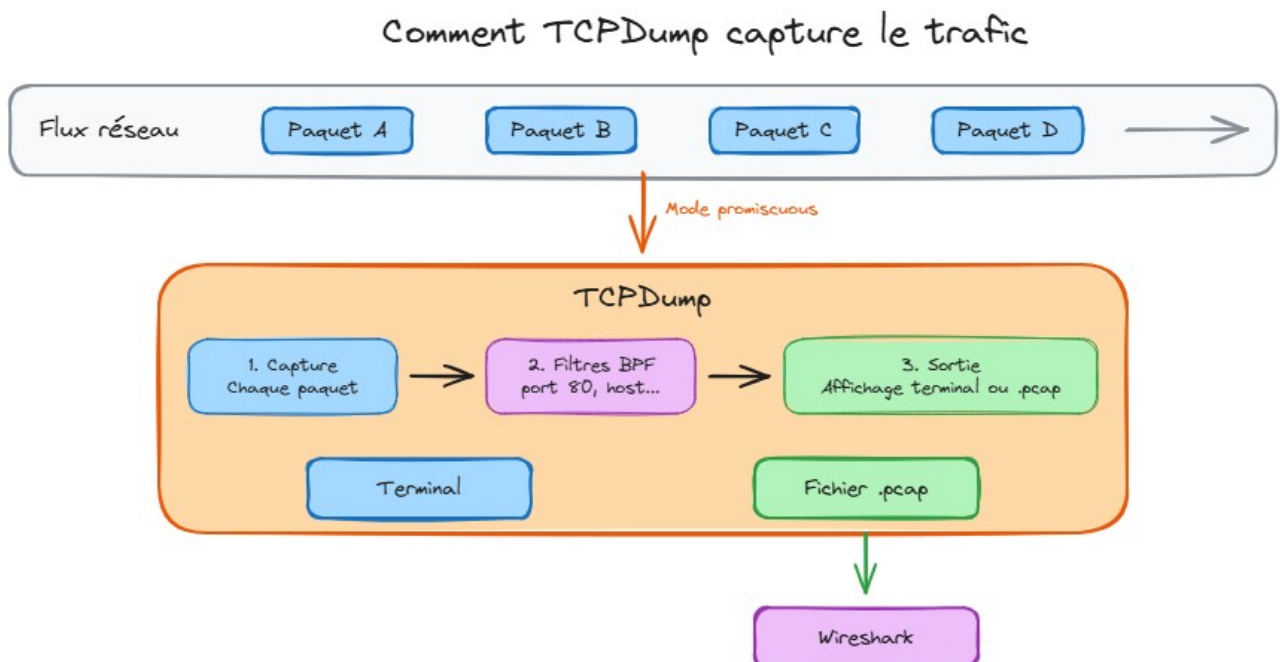
- Léger et rapide
- Fonctionne sur la majorité des systèmes Unix/Linux
- Capture ciblée via filtres BPF (Berkeley Packet Filter)

Utilisation

- Diagnostic rapide sur serveur
- Capture distante via SSH
- Analyse préalable avant import dans Wireshark

Avantages

- Idéal en environnement serveur
- Peu gourmand en ressources
- Très précis avec les filtres



Chapitre 10 – Réseau en environnement réel

Dans la pratique, les réseaux diffèrent fortement selon leur contexte : domestique, entreprise, cloud ou virtualisé. Chaque environnement possède ses spécificités techniques, ses contraintes de sécurité et ses enjeux opérationnels.

1. Réseau domestique

Le réseau domestique est conçu pour un usage personnel ou familial. Il privilégie la simplicité d'installation et d'utilisation.

Architecture typique

- Un routeur fourni par le FAI (box Internet)
- Fonction NAT (Network Address Translation)
- Wi-Fi partagé
- Quelques équipements : ordinateurs, smartphones, TV connectées, objets IoT

Fonctionnement

Le routeur joue plusieurs rôles :

- Passerelle vers Internet
- Serveur DHCP (attribution automatique d'adresses IP)
- Point d'accès Wi-Fi
- Pare-feu basique

Le NAT permet à plusieurs appareils internes d'utiliser une seule adresse IP publique.

Caractéristiques principales

- Peu ou pas de segmentation réseau
- Configuration simplifiée
- Sécurité limitée par défaut

Risques

- Appareils IoT vulnérables
- Mot de passe Wi-Fi faible
- Absence de supervision
- Mises à jour non effectuées

Bonnes pratiques

- Activer le chiffrement WPA3 ou WPA2
- Modifier les identifiants par défaut
- Mettre à jour régulièrement le routeur
- Créer un réseau invité pour isoler les appareils

2. Réseau d'entreprise

Le réseau d'entreprise est plus complexe et structuré. Il doit garantir performance, sécurité et disponibilité.

Architecture typique

- VLAN multiples pour segmenter les services
- Pare-feu professionnel
- DMZ (zone démilitarisée)
- Serveurs internes
- Systèmes de supervision
- Journaux centralisés

Segmentation par VLAN

Les VLAN permettent de séparer logiquement les services :

- VLAN utilisateurs
- VLAN serveurs
- VLAN VoIP
- VLAN invités

Cela limite la propagation d'attaques internes.

DMZ

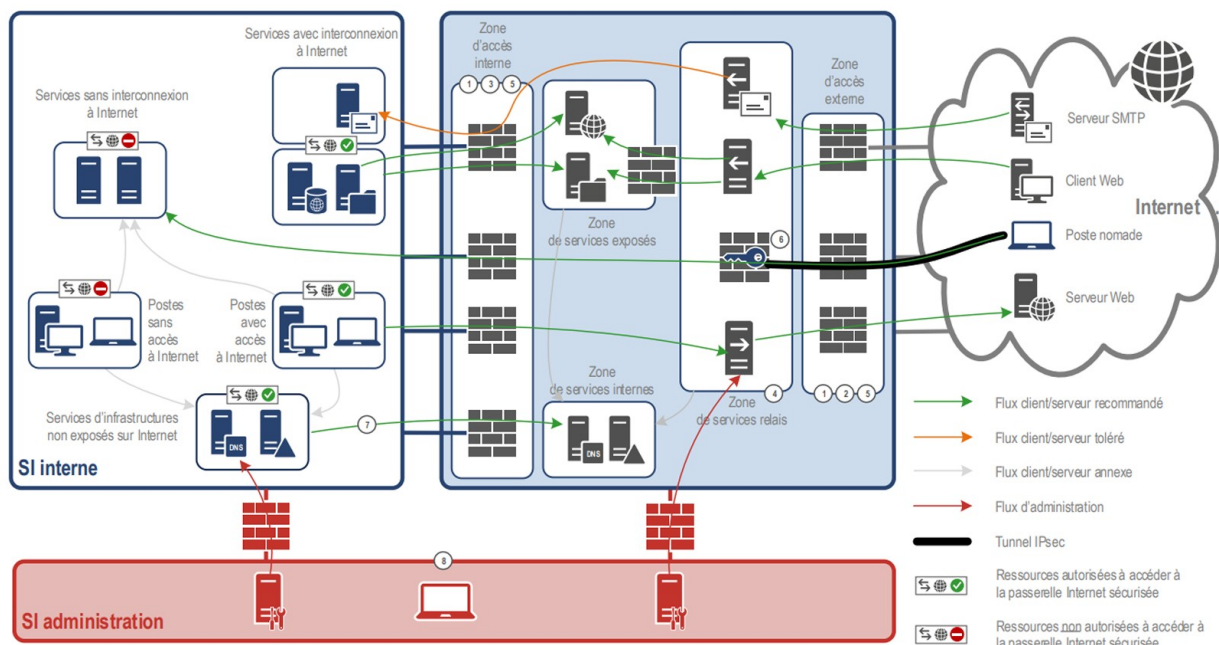
La DMZ est une zone intermédiaire entre Internet et le réseau interne. On y place les serveurs exposés (site web, mail, etc.) pour éviter un accès direct au réseau interne.

Supervision et journaux

- Centralisation des logs
- Surveillance du trafic
- Détection d'intrusions (IDS/IPS)
- Alertes en temps réel

Enjeux

- Continuité de service
- Protection des données
- Conformité réglementaire
- Gestion des accès utilisateurs



3. Réseau cloud

Le réseau cloud repose sur des infrastructures virtualisées fournies par des prestataires comme **Amazon Web Services**, **Microsoft Azure** ou **Google Cloud**.

Concepts clés

VPC / VNet

- VPC (Virtual Private Cloud) chez AWS
- VNet (Virtual Network) chez Azure

Il s'agit d'un réseau privé virtuel isolé dans le cloud.

Security Groups

Les Security Groups sont des pare-feu virtuels appliqués aux instances.

Ils contrôlent :

- Les flux entrants
- Les flux sortants
- Les ports et protocoles autorisés

Load Balancers

Les load balancers répartissent la charge entre plusieurs serveurs afin :

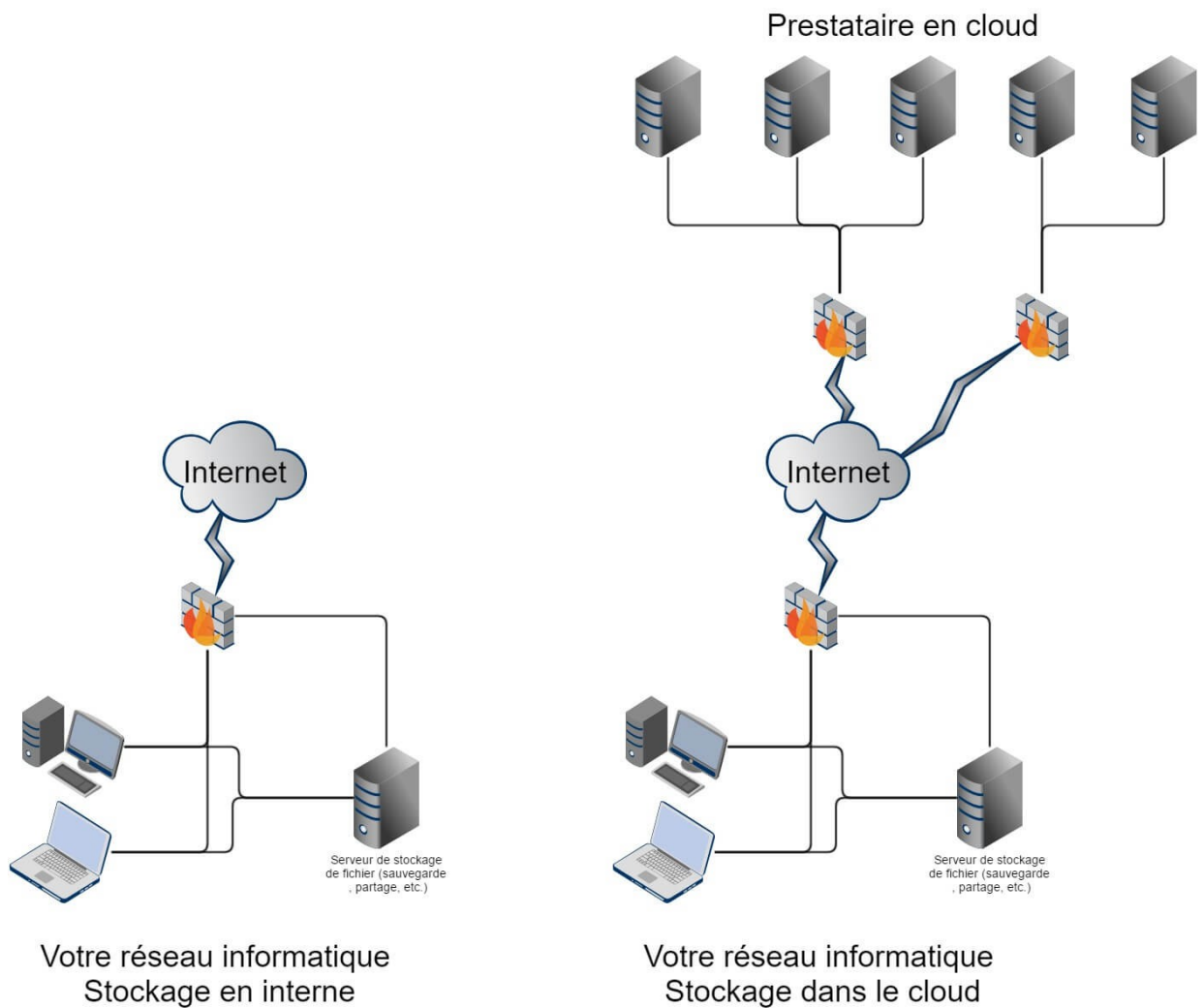
- D'améliorer la disponibilité
- D'optimiser les performances
- D'assurer la haute disponibilité

Particularités du réseau cloud

- Infrastructure entièrement virtualisée
- Configuration via interface web ou API
- Facturation basée sur l'usage
- Forte automatisation

Enjeux de sécurité

- Mauvaise configuration des règles d'accès
- Exposition accidentelle de ressources
- Gestion des identités et des permissions



4. Réseau virtualisé

Le réseau virtualisé repose sur des machines virtuelles hébergées par un hyperviseur.

Hyperviseur

Un hyperviseur permet d'exécuter plusieurs machines virtuelles sur un même serveur physique.

Exemples :

- **VMware ESXi**
- **Microsoft Hyper-V**
- **KVM**

Switch virtuel

Le switch virtuel permet aux machines virtuelles de communiquer entre elles et avec le réseau physique.

Il peut :

- Segmenter le trafic
- Appliquer des règles de sécurité
- Isoler certaines machines

Isolation des machines virtuelles

Chaque VM possède :

- Sa propre adresse IP
- Son système d'exploitation
- Son espace mémoire

L'isolation empêche théoriquement une VM d'accéder aux ressources d'une autre sans autorisation.

Enjeux

- Sécurisation de l'hyperviseur
- Risque de compromission inter-VM
- Mauvaise configuration des réseaux virtuels

Conclusion

Ce cours a permis de comprendre le fonctionnement global d'un réseau informatique, depuis les bases techniques jusqu'aux enjeux de cybersécurité.

Les modèles de référence comme le **Modèle OSI** et le **Modèle TCP/IP** structurent l'analyse des communications. L'adressage IP, le subnetting, le routage et le NAT expliquent comment les machines communiquent entre elles et avec Internet.

Les protocoles essentiels (TCP, UDP, DNS, DHCP, ARP, ICMP) et les équipements réseau (switch, routeur, pare-feu, IDS/IPS, proxy, Wi-Fi) montrent comment les données circulent, sont contrôlées et protégées.

La cybersécurité réseau repose sur :

- La segmentation (VLAN, DMZ)
- Le filtrage (pare-feu, ACL)
- Le chiffrement (HTTPS, VPN)
- La supervision et la journalisation

Les attaques étudiées (sniffing, MITM, ARP/DNS spoofing, DDoS, scan) démontrent que le réseau est la principale surface d'attaque d'un système d'information.

En résumé, maîtriser le réseau signifie comprendre à la fois le fonctionnement technique des communications et les mécanismes de protection nécessaires pour garantir confidentialité, intégrité et disponibilité des données.